

BÖLÜM 1: SİBER GÜVENLİK VE BİLGİ GÜVENLİĞİ TEMELLERİ

1. Siber Güvenlik ve Bilgi Güvenliği Farkı

- Bilgi Güvenliği (Information Security):** Bilginin biçiminden bağımsız olarak (fiziksel kağıt arşivler, sözlü iletişim veya dijital veriler) gizliliğini, bütünlüğünü ve erişilebilirliğini korumayı hedefler. Kapsamı daha geniştir ve fiziksel güvenlik unsurlarını da doğrudan içerir.
- Siber Güvenlik (Cyber Security):** Bilgi güvenliğinin siber uzay (cyberspace) ile sınırlı olan alt kümesidir. Dijital ortama aktarılmış, ağlar üzerinde taşınan veya bilgisayar sistemlerinde işlenen varlıkların güvenliğine odaklanır. Temel amacı, siber tehdit aktörlerinin dijital altyapılara sızmasını ve bu altyapıları sabote etmesini engellemektir.

2. Bilişim Güvenliğinin Temel Modelleri: CIA ve DAD Üçlüleri

Bilgi güvenliği stratejileri geliştirilirken kullanılan en temel çerçeve CIA üçlüsüdür. Savunma perspektifini tam olarak kavrayabilmek için, bu amaçları baltalamaya çalışan saldırganların odaklandığı DAD modeli ile olan ilişkisi incelenmelidir.

- Gizlilik (Confidentiality) vs. İfşa (Disclosure):** Hassas verilerin yalnızca yetkili kullanıcılar veya süreçler tarafından erişilebilir olmasını sağlamayı amaçlar. Bu ilkenin ihlali, gizli bir bilginin yetkisiz bir tarafça ele geçirilmesi yani "İfşa" durumudur. Korunması için güçlü şifreleme algoritmaları ve erişim denetimi mekanizmaları kullanılır.
- Bütünlük (Integrity) vs. Değiştirme (Alteration):** Verinin kaynağında oluşturulduğu andan hedefe ulaşana kadar yetkisiz bir şekilde değiştirilmediğini, silinmediğini veya manipüle edilmediğini garanti eder. Saldırganlar bu bütünlüğü bozmak için veriyi manipüle etme yani "Değiştirme" yöntemini kullanırlar. Korunması amacıyla hashing (özetleme) algoritmaları ve dijital imzalar uygulanır.
- Erişilebilirlik (Availability) vs. Reddetme (Denial):** Sistemlerin ve verilerin yetkili kullanıcılar tarafından ihtiyaç duyulduğu her an hazır ve çalışır durumda olmasını ifade eder. Saldırganlar sistemin meşru kullanıcılarına hizmet vermesini engellemek için "Hizmet Engelleme / Reddetme" eylemlerine başvururlar (Örn: DDoS saldırıları). Korunması için yedeklilik ve DDoS koruması yapılandırılmalıdır.

CIA ve DAD İlişki Matrisi

Güvenlik Hedefi (CIA)	Saldırı Hedefi (DAD)	Temel Koruma Mekanizması
Gizlilik (Confidentiality)	İfşa (Disclosure)	Şifreleme, Erişim Denetimi
Bütünlük (Integrity)	Değiştirme (Alteration)	Hashing, Dijital İmzalar
Erişilebilirlik (Availability)	Reddetme (Denial / Destruction)	Yedeklilik, DDoS Koruması

3. Parkerian Hexad (Altılı Güvenlik Modeli)

Geleneksel CIA üçlüsünün verinin tüm durumlarını açıklamakta yetersiz kaldığı senaryolarda, bilgi güvenliğini 6 temel element üzerinden ele alan genişletilmiş modeldir. Özellikle verinin fiziksel olarak ele geçirilmesi ancak okunamaması veya verinin kullanılabilirliğini kaybetmesi gibi spesifik durumları açıklar.

- **1. Gizlilik (Confidentiality):** Verinin yalnızca yetkili kişilerin erişimine açık olması durumudur.
- **2. Bütünlük (Integrity):** Verinin doğruluğunun korunması ve yetkisiz şekilde değiştirilmemesidir.
- **3. Erişilebilirlik (Availability):** Yetkili kullanıcıların ihtiyaç duyduğunda veriye kesintisiz ulaşabilmesidir.
- **4. Sahiplik veya Kontrol (Possession / Control):** Verinin üzerinde fiziksel veya mantıksal kontrolün sürdürülmesidir; gizlilikten bağımsızdır.
- **5. Orijinallik / Özgünlük (Authenticity):** Verinin veya iletişimin iddia edilen doğru kaynaktan geldiğinin kesin olarak kanıtlanabilmesidir. Dijital imzalar ve sertifikalar orijinallik kanıtları.
- **6. Yararlılık / Kullanışlılık (Utility):** Verinin sadece mevcut olması yetmez, aynı zamanda kullanılabilir ve faydalı bir formatta olması gerekir.

CIA ve Parkerian Hexad Karşılaştırma Matrisi

Senaryo	Gizlilik (C)	Bütünlük (I)	Erişilebilirlik (A)	Sahiplik (P)	Orijinallik (Au)	Yararlılık (U)
Şifreli verinin çalınması	Korundu	Korundu	Korundu	İhlal Edildi	Korundu	Korundu
Anahtarın kaybedilmesi	Korundu	Korundu	Korundu	Korundu	Korundu	İhlal Edildi
Sahte e-posta gönderimi	Korundu	İhlal Edildi	Korundu	Korundu	İhlal Edildi	Korundu

4. Saldırı ve Saldırı Tipleri: Tehdit Spektrumunun Analizi

Saldırıları, sisteme müdahale biçimlerine göre iki ana kategoriye ayrılır:

A. Pasif Saldırılar

Sistem kaynaklarına veya veri akışına doğrudan müdahale etmeden, iletilen bilgiyi izleme veya toplama eylemleridir. Sistem işleyişinde değişiklik yaratmadıkları için tespit edilmeleri son derece zordur. En güçlü savunma mekanizması, verinin uçtan uca şifrelenmesidir.

- **İçeriği Dinleme (Eavesdropping):** Ağ üzerinden geçen şifrelenmemiş paketlerin sniffer araçlarıyla yakalanıp okunmasıdır.
- **Trafik Analizi (Traffic Analysis):** Veri şifrelenmiş olsa dahi, iletişim kuran tarafların kimliğinin, iletişim sıklığının ve mesaj boyutlarının analiz edilerek çıkarımlar yapılmasıdır.
- **Sosyal Mühendislik:** İnsan zaafiyetlerini kullanarak sistem hakkında bilgi sızdırma eylemidir.
- **Ağ Haritalama (Network Mapping):** Hedef sistemdeki aktif cihazları, portları ve işletim sistemlerini tespit etme sürecidir.

B. Aktif Saldırılar

Veri akışını değiştiren, sahte veri üreten veya sistem kaynaklarını tüketen saldırılardır. Sistemde fark edilebilir etkiler yarattıklarından tespit edilmeleri daha kolaydır ancak verdikleri zarar anidir.

- **1. Maskeleye (Masquerade):** Bir saldırganın, yetkisiz erişim elde etmek için kendisini meşru bir kullanıcı gibi tanıtmasıdır.
- **2. Mesaj Modifikasyonu:** İletilen mesajın içeriğinin değiştirilmesi veya iletim sırasının manipüle edilmesidir; doğrudan veri bütünlüğüne yöneliktir.
- **3. Yeniden Oynatma (Replay):** Oturum sırasında yakalanan geçerli bir veri paketinin daha sonra tekrar gönderilerek sisteme yetkisiz giriş yapılmasıdır.
- **4. Hizmet Dışı Bırakma (DoS/DDoS):** Sistemin kaynaklarını tüketerek veya sunucuları sahte trafikle boğarak meşru kullanıcılara hizmet veremez hale getirilmesidir.
- **5. İnkâr Etme (Repudiation):** Bir kullanıcının gerçekleştirdiği bir eylemi veya gönderdiği bir mesajı daha sonra teknik yetersizlikleri kullanarak reddedebilmesidir.

C. Klasik Tehdit Tipleri:

- **Interception (Araya Girme):** Yetkisiz bir tarafın sistem kaynaklarına veya veriye erişim sağlamasıdır. **Gizlilik (Confidentiality)** ilkesini tehdit eden *pasif* bir saldırdır (Örn: Koklama/Sniffing).
- **Interruption (Kesinti):** Sistem kaynağının yok edilmesi veya sistemin kullanılamaz hale getirilmesidir. **Erişilebilirlik (Availability)** ilkesini hedef alan *aktif* bir saldırdır (Örn: DDoS).
- **Modification (Değiştirme):** Yetkisiz bir tarafın veriyi değiştirmesi veya manipüle etmesidir. **Bütünlük (Integrity)** ilkesini hedef alan *aktif* bir saldırdır (Örn: Veritabanı kaydını değiştirme).

- **Fabrication (Uydurma / Üretme):** Yetkisiz bir tarafın sisteme sahte nesneler veya sahte kayıtlar eklemesidir. **Orijinallik (Authenticity)** ilkesini hedef alan *aktif* bir saldırdır (Örn: Sahte ARP yanıtı).
- **Sınav Notu (Trojan Sınıflandırması):** Trojan, meşru bir yazılım maskesiyle sisteme sızıp arka planda veri sızdırdığı için öncelikli olarak **Interception (Araya Girme)**; arka kapı açıp dosya değiştirdiği durumlarda ise **Modification (Değiştirme)** tehdit tipine girer.

5. Korsanlık ve Korsan Türleri: Motivasyon ve Etik Sınıflandırma

Hacking veya korsanlık, bir bilgisayar sistemindeki zayıflıkların tespit edilip bu açıkların sistem üzerinde yetkisiz kontrol sağlamak amacıyla kullanılmasıdır. Tehdit aktörleri etik duruşlarına, yasal izinlerine ve motivasyonlarına göre sınıflandırılır.

A. Hacker Kategorileri (Şapka Renkleri)

- **Siyah Şapkalı Hackerlar (Black Hat):** Kötü niyetli, yasa dışı faaliyetler yürüten, veri hırsızlığı ve altyapı tahribatı yaparak kişisel kazanç veya zarar verme amacı taşıyan siber suçlulardır.
- **Beyaz Şapkalı Hackerlar (White Hat):** Sistem sahiplerinin yasal izniyle güvenlik açıklarını bulup raporlayan etik hackerlar veya savunma uzmanlarıdır.
- **Gri Şapkalı Hackerlar (Gray Hat):** İzinsiz olarak sistemleri illegal şekilde test eden ancak kötü niyeti olmayan, buldukları açıkların kapatılması karşılığında kurumlardan ücret talep edebilen aktörlerdir.
- **Kırmızı Şapkalı Hackerlar (Red Hat):** Siyah şapkalı hackerları durdurmak ve onları etkisiz hale getirmek için agresif, saldırgan yöntemler kullanan siber uzmanlardır.
- **Mavi Şapkalı Hackerlar (Blue Hat):** Kurumlar ve yazılım üreticileri tarafından, yeni çıkan ürünleri piyasaya sürülmeden önce test etmeleri ve açıklarını bulmaları için dışarıdan tutulan bağımsız uzmanlardır.

B. Diğer Tehdit Aktörleri

- **Script Kiddies:** Teknik becerisi ve derin kodlama bilgisi düşük olan, saldırı düzenlerken başkaları tarafından yazılmış hazır scriptleri ve otomatik araçları kullanan kişilere verilen addır.
- **Haktivistler (Hacktivists):** Siyasi, dini veya sosyal bir mesaj vermek ya da ses duyurmak amacıyla siber saldırılar gerçekleştiren motivasyonel gruplardır.
- **Devlet Destekli Aktörler (Nation-State Actors):** Hükümetler tarafından finanse edilen, askeri/stratejik istihbarat sağlamak amacıyla kritik altyapılara yönelik karmaşık ve uzun süreli casusluk/sabotaj operasyonları yürüten ekiplerdir.
- **İç Tehditler (Insider Threats):** Kurum içinde yasal erişim yetkisi bulunan ancak bu yetkiyi bilinçli veya bilinçsiz olarak kötüye kullanan mevcut/eski personel veya tedarikçilerdir. Kurumsal sınırların içinde yer aldıklarından tespiti ve engellenmesi en zor tehdit türlerindendir.

6. Zararlı Yazılımlar ve Saldırı Araçları

Zararlı yazılımlar (Malware), bir sisteme zarar vermek, bilgi sızdırmak veya yetkisiz erişim sağlamak için tasarlanmış kod parçalarıdır.

- **Virüsler:** Kendini meşru dosyalara ekleyen ve yayılmak için kesin bir kullanıcı etkileşimi (dosyanın açılması vb.) gerektiren kodlardır. (Örnek: *Melissa*).
- **Solucanlar (Worms):** Kullanıcı etkileşimi olmadan ağ üzerindeki zayıflıkları kullanarak kendi kopyalarını hızla yayan bağımsız yazılımlardır. (Örnek: *Stuxnet*, *WannaCry*).
- **Truva Atları (Trojans):** Yararlı bir yazılım süsü verilerek (maskeleye yöntemiyle) sisteme sızan ve arka kapı (backdoor) açan zararlı programlardır. (Örnek: *Zeus*).
- **Fidye Yazılımları (Ransomware):** Sistemdeki verileri şifreleyerek erişimi engelleyen ve tekrar açılması karşılığında kullanıcıdan para talebinde bulunan yazılımlardır. (Örnek: *Ryuk*, *WannaCry*).
- **Rootkitler:** İşletim sisteminin derinliklerine yerleşerek varlığını antivirüslerden gizleyen ve saldırgana sistem üzerinde tam yetki veren araçlardır.
- **Keyloggers:** Klavyedeki her tuş vuruşunu kaydedip saldırgana gönderen şifre hırsızlığı yazılım veya donanımlardır.
- **Sniffers:** Ağ trafiğini izleyip paketleri analiz eden, saldırganlar için kritik birer izleme silahı olan araçlardır.
- **Spyware (Casus Yazılım):** Kullanıcının rızası ve bilgisi olmadan sisteme sızan; arka planda internet alışkanlıklarını, şifreleri ve kişisel verileri gizlice kaydedip dışarı aktaran yazılımlardır. Keylogger'lar casus yazılımların bir alt kümesidir. (Örnek: *Pegasus*).
- **Adware (Reklam Amaçlı Yazılım):** Bilgisayarda veya tarayıcıda sürekli olarak istenmeyen reklamlar ve açılır pencereler gösteren, sistem kaynaklarını tüketerek veri güvenliğini tehdit eden yazılımlardır. (Örnek: *Fireball*).
- **Botnet (Zombi Bilgisayar Ağları):** Uzaktan kontrol edilen binlerce ele geçirilmiş cihazdan oluşan devasa ağlardır. Ağdaki cihazlara "Zombi", yöneten siber suçluya "Botmaster" denir. Botnet bir yazılım türü değil, DDoS saldırıları, spam gönderimi veya brute-force operasyonları için kullanılan bir altyapıdır. (Örnek: *Mirai*, *Emotet*).
- **Exploit (Açık Sömürücü Kodlar):** Yazılım veya donanımlardaki güvenlik açıklarını suistimal ederek sistemde yetkisiz kod çalıştırmak, sızmak veya yetki yükseltmek amacıyla yazılmış özel kodlardır.
 - **Zero-Day Exploit (Sıfırıncı Gün Sömürüsü):** Yazılım üreticisi tarafından henüz tespit edilmemiş ve yaması yayınlanmamış açıklar için kullanılan, savunulması en zor tehdit türüdür.
- **Spam (İstenmeyen E-posta):** Ticari veya kötü niyetli amaçlarla toplu olarak gönderilen yığın mesajlardır. En büyük tehlikesi, içinde zararlı yazılım barındıran ek dosyalar veya oltalama sitelerine yönlendiren linkler bulundurmasıdır.

7. İnsan Odaklı Siber Suçlar: Sosyal Mühendislik ve Kimlik Avı (Phishing) Çeşitleri

Sistemlerin en zayıf halkası olan "insan" unsurunu, psikolojik zaaflarını (güven, korku, acelecilik, merak) kullanarak bilgi sızdırmak amacıyla hedef alan saldırılardır.

A. Kimlik Avı (Phishing / Oltalama) Türleri

Saldırganların meşru ve güvenilir bir kurum gibi davranarak kurbanları hassas verileri paylaşmaya veya zararlı bağlantılara tıklamaya ikna ettiği saldırılardır.

- **Email Phishing (Genel Oltalama):** Belirli bir hedef gözetmeksizin, sahte e-postaların binlerce kişiye toplu olarak gönderildiği en yaygın oltalama türüdür.
- **Spear Phishing (Hedef Odaklı Oltalama):** Belirli bir bireyi, departmanı veya organizasyonu doğrudan hedef alan, açık kaynaklardan (OSINT) ön araştırma yapılarak hazırlanan özelleştirilmiş saldırılardır.
- **Whaling (Balina Avı):** Hedefleri sıradan çalışanlar değil; şirketin en üst düzey yöneticileri (CEO, CFO, CIO) veya yüksek profilli devlet görevlileri olan en üst düzey varyasyondur.
- **Vishing (Voice Phishing / Sesli Oltalama):** Saldırganların kurbanları telefon aramaları üzerinden, aciliyet ve korku baskısı kurarak doğrulama kodlarını (OTP) veya şifreleri almak için manipüle ettiği yöntemdir.
- **Smishing (SMS Phishing / Kısa Mesaj Oltalaması):** SMS kanalı kullanılarak gerçekleştirilen, mobil cihazlarda URL adresleri tam net görünmediği için başarı oranı yüksek olan oltalama türüdür.
- **Quishing (QR Code Phishing / QR Kod Oltalaması):** Güvenlik yazılımlarının link tabanlı engelleme sistemlerini atlatmak için geliştirilmiş, e-postanın veya broşürün içine resim olarak yerleştirilen QR kodlar üzerinden kimlik avı sitesine yönlendirme yapılan yöntemdir.

B. Pretexting (Senaryolaştırma)

Bir saldırganın kurbandan bilgi sızdırmak veya onu belirli bir eyleme zorlamak amacıyla önceden tasarlanmış sahte bir senaryo ve yapay bir kimlik üzerine kurduğu sosyal mühendislik yöntemidir. Geleneksel oltalama saldırılarının aksine, kurbanı doğrudan link göndermek yerine öncelikle sahte kimlikler üzerinden bir **güven ilişkisi** kurulması amaçlanır. Kurban kurumsal veya kişisel verileri kendi eliyle teslim eder.

BÖLÜM 2: KİMLİK YÖNETİMİ VE ERİŞİM DENETİMLERİ

Kurumsal Roller ve Görevleri:

- **CIO (Chief Information Officer - Bilişim Kurulu Başkanı):** Kurumun tüm bilişim ve teknoloji (BT) altyapısını, stratejilerini ve yatırımlarını yöneten en üst düzey yöneticidir.
- **CISO (Chief Information Security Officer - Bilgi Güvenliği Başkanı):** Kurumun siber güvenlik stratejilerini, risk yönetimini ve yasal uyumluluk süreçlerini yöneten en üst düzey güvenlik yöneticisidir.

- **SE (System Engineer - Sistem Mühendisi):** Kurumsal bilişim altyapısının (sunucu, depolama, ağ) mimarisini tasarlayan, kuran ve entegrasyonu sağlayan uzmandır.
- **SA (System Administrator - Sistem Yöneticisi):** Kurulmuş olan mevcut sistemlerin günlük işletimini, bakımını, güncellemelerini ve kullanıcı erişim sorunlarını yöneten teknik personeldir.

1. Tanımlama ve Doğrulama (Identification & Authentication)

Güvenlik mimarisinin ilk adımı sisteme erişmek isteyen varlığın kimliğinin tespit edilmesi ve kanıtlanmasıdır.

- **A. Tanımlama (Identification) Süreci:** Kullanıcının sisteme bir kimlik iddiası sunmasıdır (Kullanıcı adı, personel ID numarası veya e-posta adresi). Tek başına güven sağlamaz, sadece sistemdeki bir kayda atıfta bulunur.
- **B. Doğrulama (Authentication) Mekanizmaları:** Sunulan kimlik iddiasının gerçekliğinin test edilmesidir. NIST 800-63 standartları doğrulamayı dört temel faktör gücüne göre sınıflandırır:
 - **Bildiğiniz Şey (Knowledge Factor):** Şifreler, PIN'ler veya güvenlik sorularıdır. Başkaları tarafından öğrenilme veya kaba kuvvet saldırılarıyla kırılma riski yüksektir.
 - **Sahip Olduğunuz Şey (Possession Factor):** Akıllı kartlar, donanım tokenları, SMS ile gelen OTP kodları veya mobil onay bildirimleri gibi fiziksel varlıklardır.
 - **Olduğunuz Şey (Inherence Factor):** Parmak izi, yüz tanıma, iris taraması veya ses analizi gibi biyometrik verilerdir. Taklit edilmesi en zor faktördür.
 - **Yaptığınız Şey (Behavioral Factor):** Klavyede yazı yazma ritmi (keystroke dynamics) veya fareyi kullanma biçimi gibi dinamik davranış kalıplarıdır.
- **C. Çok Faktörlü Doğrulama (MFA) ve NIST Güven Seviyeleri:** Sistemlerin güvenliği için en least iki farklı kategorideki faktörün kombinasyonu zorunlu kılınır.
 - *Kritik Sınav Notu:* "Şifre + SMS kodu" farklı kategoride oldukları için gerçek bir MFA'dir. Ancak "şifre + güvenlik sorusu" kombinasyonu gerçek bir MFA değildir; çünkü her iki bileşen de aynı kategoridedir ("bildiğiniz şey").
 - **IAL (Identity Assurance Level):** Kayıt esnasında gerçek kimliğin ne kadar sıkı doğrulandığını ifade eder (IAL1-IAL3).
 - **AAL (Authenticator Assurance Level):** Doğrulama cihazının siber saldırılara karşı direncini tanımlar (AAL1-AAL3).
 - **FAL (Federation Assurance Level):** Kimlik bilgilerinin sistemler arası paylaşılma (federasyon) güvenliğini belirler.

2. Yetkilendirme ve Eriřim Denetiminin Mimari Çerçevesi

Doğrulan kullanıcıların sistem kaynakları üzerindeki hakları yetkilendirme aşamasında kurallarla belirlenir. Korunan varlığın doğasına göre üç ana başlıkta sınıflandırılır:

- Ağ Eriřimi (Network Access Control - NAC):** Cihazların kurumsal ağ altyapısına dahil olma yetkilerini denetler.
- Sistem Eriřimi (System Access Control):** İşletim sistemleri, sunucular ve terminal seviyesindeki oturum açma yetkilerini kapsar.
- Veri Eriřimi (Data Access Control):** Veritabanı tabloları, dosya sunucuları ve hassas dokümanlara yönelik okuma, yazma, silme ve değiştirme yetkilerini kontrol eder.

A. Eriřim Kontrolünün Altın İlkeleri

- Need to Know (Bilmesi Gereken Kadar İlkesi):** Çalışanın, yalnızca kendisine verilen görevi tamamlaması için kesinlikle görmesi gereken verilere erişebilmesidir. Veri gizliliğini korumayı amaçlar.
- Least Privilege (En Az Yetki Prensibi):** Kullanıcının sistem üzerinde işini yapabilmesi için ihtiyaç duyduğu minimum yetki seviyesine (okuma, yazma vb.) sahip olmasıdır. Amaç, hesap ele geçirme durumlarında saldırganın etki alanını kısıtlamaktır.

B. Eriřim Kontrol Katmanları (Savunma Derinliğı)

Kontrol Katmanı	Tanımı ve Amacı	Gerçek Dünya Örnekleri
Yönetimsel Kontroller	Yönetim tarafından oluşturulan yasal, politik ve kurumsal kurallardır.	Güvenlik politikaları, prosedürler, işe alım öncesi arka plan taramaları, farkındalık eğitimleri.
Teknik / Mantıksal Kontroller	Bilgi sistemlerini ve verileri korumak için uygulanan yazılım ve donanım tabanlı teknolojik bariyerlerdir.	Şifreleme algoritmaları, Güvenlik Duvarları (Firewall), Eriřim Kontrol Listeleri (ACL), MFA, IDS/IPS.
Fiziksel Kontroller	Sunucu odalarına ve şirket binalarına fiziksel erişimi denetleyen somut unsurlardır.	Kartlı geçiş sistemleri, biyometrik kapı kilitleri, güvenlik kameraları (CCTV), kilitli sunucu kabinleri.

C. AAA Çerçevesi (Framework)

- 1. Authentication (Kimlik Doğrulama): Sisteme erişmek isteyen varlığın kimliğinin gerçek olup olmadığının test edilip kanıtlanması aşamasıdır.
- 2. Authorization (Yetkilendirme): Kimliği doğrulanan kullanıcının hangi kaynaklara erişebileceğinin ve hangi aksiyonları alabileceğinin kurallarla belirlenmesidir.
- 3. Accounting (Hesap Verebilirlik): Kullanıcının gerçekleştirdiği tüm eylemlerin zaman damgalı (UTC) olarak kronolojik biçimde loglanması ve denetlenmesidir. Adli bilişim (forensics) incelemelerinin temelidir.

3. Temel Erişim Denetimi Modelleri

- İsteğe Bağlı Erişim Denetimi (DAC):** Veri veya kaynak sahibi, ilgili varlık üzerindeki erişim haklarını tamamen kendi iradesiyle belirler. Esnektir ancak merkezi takibi ve yönetimi zordur.
- Zorunlu Erişim Denetimi (MAC):** Erişim kararları, merkezi bir otorite tarafından dayatılan güvenlik etiketlerine (Gizli, Çok Gizli vb.) dayanır; kullanıcılar izinleri değiştiremez. Askeri ve devlet sistemlerinde tercih edilir.
- Rol Tabanlı Erişim Denetimi (RBAC):** Yetkiler bireysel kullanıcılara değil, organizasyon içindeki rollere atanır. Kurumsal ölçekteki yapılarda en yaygın kullanılan modeldir.
- Öznitelik Tabanlı Erişim Denetimi (ABAC):** Erişim kararları; kullanıcı, kaynak ve çevresel özniteliklerin (zaman, coğrafi konum, cihaz türü) anlık analiziyle dinamik olarak verilir.

Erişim Denetimi Modelleri Karşılaştırma Matrisi

Özellik	DAC	MAC	RBAC	ABAC
Yetki Kararı	Kaynak Sahibi	Sistem / Merkezi Otorite	Kullanıcı Rolü	Çoklu Öznitelikler
Esneklik	Çok Yüksek	Çok Düşük	Orta	Çok Yüksek
Güvenlik Düzeyi	Düşük - Orta	Çok Yüksek	Yüksek	Çok Yüksek
Ölçeklenebilirlik	Düşük	Düşük	Yüksek	Çok Yüksek

4. Modern Kimlik Doğrulama Protokolleri ve Kurumsal Dizin Servisleri

- **SAML 2.0:** XML tabanlı bir protokoldür. Genellikle kurumsal federasyon yapılarında ve Tek Oturum Açma (SSO) sistemlerinde kimlik doğrulaması için tercih edilir.
- **OAuth 2.0:** Kullanıcı şifresini paylaşmadan, bir uygulamanın başka bir servisteki belirli kaynaklara kullanıcı adına erişmesini sağlayan bir **yetkilendirme çerçevesidir**. Token tabanlı çalışır.
- **OpenID Connect (OIDC):** OAuth 2.0 protokolü üzerine inşa edilmiş bir **kimlik doğrulama katmanıdır**. Sosyal medya hesaplarıyla farklı sitelerde oturum açabilmeyi (sosyal login) sağlar.
- **IDAM (Identity and Access Management):** Kullanıcının kurumsal yaşam döngüsünü yönetir; işe alımda hesap açılması (**Provisioning**) ve ayrılımda hesabın kapatılması (**Deprovisioning**) süreçlerini kapsar.
- **SSO (Single Sign-On - Tek Oturum Açma):** Kullanıcının tek bir kimlik bilgisi setiyle giriş yaparak, kurumsal ağdaki birden fazla uygulamaya tekrar şifre girmeden erişebilmesini sağlayan mimaridir. Merkezi SSO servisi (Identity Provider - IdP) kullanıcıya token verir, uygulamalar (Service Provider - SP) bu token'ı doğrular.
- **LDAP (Lightweight Directory Access Protocol):** IP ağları üzerindeki hiyerarşik dizin servislerinde kullanıcı ve cihaz bilgilerini sorgulamak için kullanılan açık bir uygulama katmanı protokolüdür. Verileri **ters ağaç** yapısında tutar; okuma işlemlerinde hızlı, yazmada yavaştır.
- **Active Directory (AD):** Microsoft tarafından geliştirilmiş, kurumsal ağ nesnelerini tek merkezden yöneten dizin servsidir. Nesneleri sorgulamak için arka planda **LDAP** protokolünü, kimlik doğrulamada ise bilet tabanlı **Kerberos** protokolünü kullanır.

5. İzleme ve Kaydetme (Auditing & Logging) ve NIST 800-92 Standartları

- **Loglama (Logging):** Olayların kronolojik olarak otomatik şekilde kayıt altına alınması sürecidir.
- **Denetleme (Auditing):** Log kayıtlarının analiz edilerek güvenlik ihlallerinin tespiti ve kurumsal/yasal uyumlulukların kontrol edilmesidir.

A. NIST 800-92 Standardına Göre Log Yönetimi İlkeleri

- **Neler Loglanmalı?:** Başarılı/başarısız kullanıcı girişleri, sistem hataları, yönetici (admin) yetkisiyle yapılan işlemler, ağ bağlantısı değişiklikleri ve hassas dosyalara yönelik aksiyonlar kaydedilmelidir.
- **Log Kaydının Temel Bileşenleri:** Zaman damgası (UTC), eylemi gerçekleştiren aktör (IP/Kullanıcı adı), olayın türü, etkilenen hedef nesne ve işlemin nihai sonucu.
- **Log Güvenliği ve Kök Neden Analizi:** Loglar şifrelenmeli ve gerçek zamanlı olarak merkezi bir **SIEM** sunucusuna aktarılmalıdır. Arşivlenen loglar, üzerinde silme veya değiştirme yapılması donanımsal olarak engellenmiş **WORM** (Write Once Read Many) güvenli depolama alanlarında saklanmalıdır.

BÖLÜM 3: RİSK YÖNETİMİ VE GÜVENLİK STRATEJİLERİ

Siber güvenlik mimarisinde mutlak (yüzde yüz) bir koruma sağlamak imkansızdır. Güvenlik; altyapıdaki risklerin tamamen yok edilmesi değil, kurumsal ve teknik önlemlerle kabul edilebilir bir seviyeye indirilmesi sürecidir.

1. Risk Kategorileri ve Hesaplama Metodolojisi

Risk yönetiminde, savunma stratejisini doğru kurgulamak için üç ana risk türü birbirinden ayırt edilmelidir:

- **Doğal Risk (Inherent Risk):** Kurumda hiçbir güvenlik kontrolü, firewall veya önlem uygulanmadığında var olan ham risk seviyesidir.
- **Kontrol Riski (Control Risk):** Mevcut güvenlik önlemlerinin ve bariyerlerinin (teknik veya yönetsel) bir saldırı karşısında başarısız olma veya bypass edilme olasılığıdır.
- **Kalıntı Risk (Residual Risk):** Gerekli tüm teknolojik ve idari güvenlik önlemleri alındıktan sonra geriye kalan, sıfırlanamayan risktir. Organizasyonun üst yönetimi tarafından bu riskin farkında olunması ve resmi olarak "kabul edilmesi" gerekir.

Risk Puanlaması: Akademik ve kurumsal risk analizlerinde riskin matematiksel değeri şu temel formülle hesaplanır:

$$\text{Risk} = \text{Tehdidin Gerçekleşme Olasılığı} \times \text{Sisteme Yaratacağı Etki}$$

2. NIST 800-30: Risk Değerlendirme Adımları

NIST 800-30 kılavuzu, kurumsal bilişim altyapılarında risklerin proaktif olarak yönetilmesi için 4 adımdan oluşan döngüsel bir metodoloji önerir:

1. **Hazırlık (Preparation):** Analizin kapsamının belirlenmesi, organizasyonel sınırların çizilmesi ve korunacak tüm bilgi/donanım varlıklarının (envanterin) çıkarılması aşamasıdır.
2. **Değerlendirme (Assessment):** Potansiyel siber tehditlerin tespiti, sistemdeki mevcut teknik zayıflıkların (vulnerabilities) analizi ve formüle göre risk seviyelerinin hesaplanması adımıdır.
3. **İletişim (Communication) ve Yanıt:** Bulguların üst paydaşlara raporlanması ve tespit edilen risklere karşı uygulanacak **4 temel stratejinin** belirlenmesidir:
 - **Azaltma (Mitigation):** Teknik önlemlerle riski düşürmektir.
 - **Aktarma (Transfer):** Riski üçüncü bir tarafa devretmektir (Örn: Siber güvenlik sigortası yaptırmak).
 - **Kabul Etme (Acceptance):** Maliyet veya etki düşüklüğü nedeniyle kalıntı riski onaylamaktır.
 - **Kaçınma (Avoidance):** Riski doğuran faaliyeti veya teknolojiyi tamamen durdurarak riskten uzaklaşmaktır.
4. **Süreklilik (Continuity):** Tehdit ortamı sürekli değiştiğinden, kurumun risk profilinin düzenli olarak izlenmesi, denetlenmesi ve güncellenmesi sürecidir.

BÖLÜM 4: AĞ GÜVENLİĞİ VE PROTOKOL TABANLI SAVUNMA TEKNOLOJİLERİ

Ağ güvenliği; ağ altyapısı üzerindeki veri trafiğinin kontrol edilmesini, yetkisiz erişimlerin engellenmesini ve protokol bazlı siber saldırıların proaktif olarak önlenmesini kapsar.

1. Güvenlik Duvarı (Firewall) ve Sınır Savunması

- Temel İşlevi:** Güvenilen bir iç ağ (kurumsal yerel ağ) ile güvenilmeyen bir dış ağ (internet) arasındaki veri trafiğini, önceden tanımlanmış kurallar çerçevesinde denetleyen, geçişine izin veren veya engelleyen bir güvenlik bariyeridir. Ağ katmanından geçen veri paketlerinin başlık bilgilerini (Kaynak/Hedef IP adresleri, Kaynak/Hedef Port numaraları ve kullanılan Ağ Protokolleri) inceleyerek kural listesiyle (ACL) eşleştirir.
- Uygulama Biçimleri:** Kurumsal ağlarda genellikle bu işe tahsis edilmiş özel **Donanımsal** cihazlar konumlandırılırken; kişisel bilgisayarlarda işletim sistemiyle bütünleşik çalışan **Yazılımsal** çözümler (Windows Defender gibi) kullanılır.

Güvenlik Duvarı Filtreleme Yöntemleri:

- Paket Filtreleme (Packet Filtering - Stateless):** Paketlerin sadece kaynak/hedef IP, port ve protokol (TCP/UDP) bilgilerine bakar. Geçmiş bağlantı durumunu takip etmez.
- Durumsal Denetim (Stateful Inspection):** Paketleri ait oldukları bağlantının durumuna (oturum tablosuna) göre denetler. Sadece içeriden başlatılmış meşru oturumların dönüş paketlerine izin verir.
- Uygulama Katmanı Filtreleme (Application-Level / Proxy):** Trafiği OSI modelinin en üst katmanında (HTTP, FTP vb.) inceler. Paket içeriğini derinlemesine analiz ederek zararlı verileri engeller.
- Devre Seviyesi Geçitleri (Circuit-Level Gateway):** Paket içeriğine bakmaksızın, iki host arasında kurulan TCP el sıkışmasının (Handshake) ve oturum güvenliğinin kurallara uygunluğunu denetler.

2. IDS ve IPS (Saldırı Tespit ve Engelleme Sistemleri)

Ağ trafiğini sadece paket başlıklarına göre değil, paketin taşıdığı verinin içeriğine (payload) ve saldırı imzalarına göre analiz eden sistemlerdir.

Özellik	IDS (Intrusion Detection System)	IPS (Intrusion Prevention System)
Temel Görevi	Ağdaki şüpheli aktiviteleri ve saldırıları tespit eder, alarm üretir.	Saldırıyı anlık olarak tespit eder ve aktif müdahaleyle durdurur.
Aksiyon Türü	Pasiftir; trafiğe doğrudan müdahale etmez, sadece loglar ve raporlar.	Aktiftir; zararlı trafiği anında kesebilir, IP'yi engelleyebilir.
Ağ Konumu	Genelde ağ hattına paralel bağlanır, ağın bir kopyasını izler (<i>Mirroring / SPAN</i>).	Doğrudan ana trafik hattı üzerinde yer alır, trafik içinden geçer (<i>In-line</i>).

- **Kritik Analoji:** Firewall "kapıdaki kilit" gibidir; sadece içeri kimin girip çıkacağına (IP/Port) bakar. IDS/IPS ise "içerideki güvenlik kamerası ve koruma" gibidir; içeri giren kişinin içerideki hareketlerini, davranış kalıplarını ve zararlı niyetini analiz eder.

3. Windows Ağ Trafiği ve Sistem Yönetimi Komutları

Windows işletim sistemlerinde ağ trafiğini komut satırından yönetmek ve telemetri verilerini kısıtlayarak sistem performansını optimize etmek amacıyla şu pratik komutlar kullanılır:

- **Gelişmiş Güvenlik Duvarı Kuralı Ekleme (netsh advfirewall):** Belirli bir uygulamanın dış ağa erişimini kesmek veya yeni bir kural tanımlamak için kullanılır.

Notepad uygulamasının internete çıkışını engelleme komutu:

```
netsh advfirewall firewall add rule name="BlockNotepad" dir=out action=block  
program="C:\Windows\System32\notepad.exe" enable=yes
```

4. Güvenli İletişim Protokolleri: SSL ve TLS

- **Nedir?:** Ağ üzerinde taşınan verilerin şifrelenerek üçüncü şahıslar tarafından okunmasını (pasif saldırıları) engellemek, iletişimin gizliliğini ve bütünlüğünü korumak amacıyla kullanılan kriptografik güvenlik protokolleridir.
- **SSL (Secure Sockets Layer):** 1990'larda geliştirilen ilk sürümdür; ancak tasarımsal açıklarından dolayı günümüzde tamamen kullanımdan kaldırılmış ve güvensiz kabul edilmiştir.
- **TLS (Transport Layer Security):** SSL protokolünün ardılı olan, güncel, yamalanmış ve güvenli standarttır. OSI modelinde **Taşıma Katmanı (Layer 4)** ile **Uygulama Katmanı (Layer 7)** arasında konumlanır ve **TCP** üzerinde çalışır.

SSL/TLS Nerede Kullanılır?

1. **Web Trafiğinde (HTTPS):** Tarayıcı ile web sunucusu arasındaki veri akışını (giriş bilgileri, kredi kartı kodları vb.) şifrelemede kullanılır.
2. **E-posta İletişiminde (SMTPS / IMAPS / POP3S):** Kurumsal veya kişisel e-postaların sunucular arasında güvenli taşınmasında kullanılır.
3. **Dosya Transferinde (FTPS):** Ağ üzerinden yapılan hassas dosya aktarımlarının şifrelenmesinde kullanılır.
4. **Uzaktan Erişimde (SSL VPN):** Şirket ağlarına dışarıdan güvenli ve şifreli tüneller üzerinden bağlanmak için kullanılır.

5. ARP Protokolü ve ARP Spoofing (Zehirlenme)

- **ARP (Address Resolution Protocol):** IP adreslerini yerel ağdaki fiziksel MAC adreslerine eşleyen kritik bir katman-2 protokolüdür. En büyük zayıflığı, **tasarımsal olarak hiçbir güvenlik doğrulaması yapmamasıdır**; gelen her ARP yanıtını doğru kabul eder.
- **ARP Spoofing (ARP Zehirlenmesi):** Saldırganın, ağ geçidinin (Gateway) veya hedef kurbanın IP adresini kendi MAC adresiyle eşleştiren sahte ARP yanıt paketlerini ağa yaymasıdır. Bu sayede tüm trafik saldırganın bilgisayarını üzerinden akmaya başlar (Ortadaki Adam - MitM Saldırısı).

Teşhis ve Korunma Yöntemleri

- **arp -a:** Sistemdeki aktif ARP tablosunu (IP-MAC eşleşmelerini) görüntülemek için kullanılır. Eğer farklı IP adreslerinin karşısında aynı MAC adresi görünüyorsa, yerel ağda bir ARP Spoofing saldırısı olma ihtimali çok yüksektir.
- **arp -s <IP> <MAC>:** Kritik eşleşmeleri kalıcı hale getirmek için **Statik ARP** kaydı ekler. Statik kayıtlar sahte ARP paketleriyle değiştirilemez.
- **DAI (Dynamic ARP Inspection):** Modern kurumsal ağ anahtarlarında (switch) kullanılan, sahte ARP paketlerini donanımsal seviyede engelleyen en güçlü ağ koruma teknolojisidir.

BÖLÜM 5: AĞ GÜVENLİĞİ VE ZAFİYET ANALİZ ARAÇLARI

Ağ güvenliğini sağlamanın ilk adımı, ağın mevcut durumunun haritasını çıkarmak, aktif cihazları tespit etmek ve bu cihazlar üzerindeki potansiyel güvenlik açıklarını siber suçlulardan önce bulup kapatmaktır. Bu amaçla en yaygın kullanılan iki temel araç **Nmap** ve **Tenable Nessus**'tur.

1. Nmap (Network Mapper) ve Port Tarama Pratikleri: Nmap; ağ keşfi, aktif cihaz tespiti, açık portların bulunması, çalışan servislerin/versiyonların ve hedef sistemin işletim sisteminin belirlenmesi amacıyla kullanılan açık kaynaklı bir aktif ağ tarama aracıdır.

Tarama sonuçlarında hedef portlar için üç temel durum listelenir:

- **Open (Açık):** Portu dinleyen bir uygulama vardır ve bağlantı kabul etmektedir.
- **Closed (Kapalı):** Port erişilebilirdir ancak onu dinleyen herhangi bir aktif servis yoktur.
- **Filtered (Filtrelendi):** Trafığın arasına bir Güvenlik Duvarı (Firewall) veya paket filtresi girdiğinden Nmap portun açık veya kapalı olduğunu algılayamamaktadır.

Sık Kullanılan Nmap Parametreleri ve İşlevleri

- **nmap -sn <hedef> (Ping Scan):** Belirtilen ağ aralığındaki cihazlara sadece ping (ICMP) istekleri göndererek hangi hostların aktif olduğunu bulur. Port taraması yapmadığı için son derece hızlıdır.
- **nmap -sS <hedef> (SYN Stealth Scan):** Varsayılan ve en popüler yarı açık tarama türüdür. Hedefle tam bir TCP üçlü el sıkışması gerçekleştirmez. SYN paketi gönderir, karşıdan SYN-ACK gelirse portun açık olduğunu anlar ancak bağlantıyı tamamlamadan RST (Reset) paketi göndererek kapatır. Hedef sistemin loglarında iz bırakma ihtimali düşüktür.
- **nmap -sT <hedef> (TCP Connect Scan):** Hedef portla tam bir TCP üçlü el sıkışması gerçekleştirir. Sistemde root (yönetici) yetkisi yoksa mecburen bu tarama kullanılır. Loglarda kesin olarak iz bıraktığı için gizli değildir.
- **nmap -sV <hedef> (Version Detection):** Açık portlarda çalışan servislerin tam olarak hangi isim ve versiyonda çalıştığını tespit eder. Sömürü (exploit) aşaması için en kritik adımdır.

- **nmap -O <hedef> (OS Detection):** Hedef cihazın hangi işletim sistemini ve çekirdek (kernel) versiyonunu kullandığını tahmin etmek için TCP/IP yığın davranışlarını analiz eder.
- **nmap -p <port_aralığı> <hedef>:** Sadece belirtilen portları tarar (Örn: -p 1-1024). 65535 portun tamamını taramak için -p- parametresi kullanılır.
- **nmap -A <hedef> (Aggressive Scan):** Agresif tarama modudur. İşletim sistemi tespiti (-O), versiyon tespiti (-sV), script taraması (-sC) ve traceroute adımlarını tek bir komutla birleştirir. Çok fazla trafik yarattığı için kolayca fark edilir.

2. Tenable Nessus ve Zafiyet Analizi

Nessus; ağdaki cihazları tarayarak üzerlerindeki bilinen yazılımsal güvenlik açıklarını, hatalı yapılandırmaları ve eksik yamaları tespit eden kurumsal bir Zafiyet Tarama (Vulnerability Assessment) aracıdır.

- **Çalışma Mantığı:** Nessus, kendi veritabanındaki güncel zafiyet kodlarını (CVE) baz alarak ağdaki cihazlara özel paketler gönderir ve aldığı yanıtları zafiyet veritabanıyla eşleştirir.
- **Eklentiler (Plugins):** Nessus'un beyni "Plugin" adı verilen küçük kod parçacıklarıdır. Her bir plugin, spesifik bir güvenlik açığını test etmek için yazılmıştır.

 **Nmap ve Nessus Arasındaki Temel Fark:** Nmap bir keşif ve haritalandırma aracıdır; kapıları (portları) ve içeride çalışan servisleri söyler ancak o kapıların kilitlerinin kırılıp kırılmayacağını analiz etmez. Nessus ise bir zafiyet tespit aracıdır; bulunan o açık kapılardan içeri siber suçluların sızıp sızamayacağını test eder ve çözüm önerileri sunar.

CVSS (Common Vulnerability Scoring System) Risk Dağılımı

Nessus, tespit ettiği zafiyetleri dünya standardı olan CVSS tabanında 0.0 ile 10.0 arasında puanlayarak şu kategorilerde raporlar:

- **CRITICAL (Kritik) | [9.0 - 10.0]:** Saldırganın hiçbir kullanıcı etkileşimi olmadan, uzaktan doğrudan kod çalıştırmasına (RCE) izin veren en tehlikeli açıklardır. Acilen yamanmalıdır. (Örn: *EternalBlue zafiyeti*).
- **HIGH (Yüksek) | [7.0 - 8.9]:** Saldırganın sistemdeki hassas verileri sızdırmasına veya yetki yükseltmesine (privilege escalation) izin veren yüksek riskli açıklardır. (Örn: *SQL Injection açıkları*).
- **MEDIUM (Orta) | [4.0 - 6.9]:** Sömürülmesi daha karmaşık olan, saldırganın sistem hakkında detaylı bilgi toplamasını sağlayan veya Hizmet Dışı Bırakma (DoS) riskleri barındıran açıklardır. (Örn: *Kimlik doğrulama mekanizmasında brute-force korumasının/hız sınırlamasının olmaması*).
- **LOW (Düşük) | [0.1 - 3.9]:** Saldırganın doğrudan sisteme sızmasını sağlamayan ancak sisteme dair mimari ipuçları veren ufak yapılandırma hatalarıdır. (Örn: *Sistem saat senkronizasyonunun (NTP) hatalı olması*).

- **INFO (Bilgi) | [0.0]:** Bir zafiyet değildir. Sadece sistemde hangi servislerin çalıştığını ve ağ haritasını gösteren referans raporlama verileridir. (Örn: *Nmap tarama sonuçlarının Nessus raporuna eklenmesi*).

BÖLÜM 6: BİLİŞİM SUÇLARI VE YASAL ÇERÇEVE

Türkiye'de siber uzayda işlenen suçlar, **5237 sayılı Türk Ceza Kanunu (TCK)** kapsamında, "Bilişim Alanında Suçlar" başlığı altında (Madde 243-246) düzenlenmiştir.

Adım 1: Bilişim Sistemine Yetkisiz Erişim (TCK Madde 243)

Bir sisteme hukuka aykırı olarak giren veya orada kalmaya devam eden kişi cezalandırılır. Eğer bu eylem nedeniyle veriler değişirse veya silinirse ceza artar.

Adım 2: Sistemi Engelleme ve Veri Manipülasyonu (TCK Madde 244)

Sistemin işleyişini bozan (DoS vb.) veya verileri değiştiren, silen, başka yere gönderen kişilere yönelik yaptırımları kapsar. Kamu kurumlarına veya bankalara yönelik saldırılarda ceza yarı oranında artırılır.

Adım 3: Banka ve Kredi Kartı Suçları (TCK Madde 245)

Başkasına ait kart bilgilerini rızasız kullanmak veya sahte kart üretmek gibi eylemleri kapsar. En ağır bilişim suçları arasındadır.

Adım 4: Yasak Cihaz ve Programlar (TCK Madde 245/A)

Münhasıran suç işlemek amacıyla üretilmiş yazılımları (exploit, sniffer vb.) bulundurmak veya satmak suçtur.

BÖLÜM 7: LINUX/UNIX KULLANICI YÖNETİMİ VE GÜVENLİĞİ (BÖLÜM 1)

Linux ve Unix türevi işletim sistemleri, tasarımları gereği çok kullanıcı (multi-user) ve çok görevli (multi-tasking) yapılardır. Sistem güvenliği, her kullanıcının doğru şekilde tanımlanması, yetkilendirilmesi ve sistem kaynaklarına erişiminin işletim sistemi seviyesinde kısıtlanmasıyla başlar.

1. Linux Kimlik Doğrulama Veritabanları (Kritik Sistem Dosyaları)

Linux sistemlerde bir kullanıcının varlığı, hakları ve kimlik doğrulama parametreleri sistemdeki belirli metin dosyalarında tutulan kayıtlar üzerinden yönetilir.

- **/etc/passwd Dosyası:** Sistemdeki tüm kullanıcı hesaplarının temel bilgilerini (kullanıcı adı, UID, GID, açıklama, ev dizini ve varsayılan kabuk) barındırır. Sistemdeki tüm kullanıcılar tarafından okunabilir (read-only) yapıdadır. Bir kullanıcının bu veritabanındaki kaydını doğrudan terminalde doğrulamak için `getent passwd username` komutu kullanılır.
- **/etc/shadow Dosyası:** Kullanıcıların şifrelerinin kriptografik özetlerini (hash) ve hesap yaşlanma (aging) politikalarını barındıran, güvenlik nedeniyle sadece root (yönetici) yetkisiyle okunabilen kritik dosyadır. Eskiden şifre hash'leri de `/etc/passwd` içinde

tutulmaktaydı; ancak herkes okuyabildiği için kaba kuvvet saldırılarına davetiye çıkarıyordu. Modern mimaride şifreler gölgelenerek shadow dosyasına taşınmıştır.

2. İki Temel Hesap Ekleme Yaklaşımı: useradd ve adduser Farkı

- **useradd (Düşük Seviyeli / Low-level):** Doğrudan sistem ikili (binary) dosyasıdır. Arka planda hiçbir şeyi otomatik yapmaz; ev dizini oluşturma, kabuk atama gibi tüm kararları parametrelerle yöneticinin vermesini bekler. Script yazarken veya otomasyon süreçlerinde tahmin edilebilir sonuçlar verdiği için tercih edilir.
- **adduser (Yüksek Seviyeli / High-level):** Arka planda useradd komutunu kullanan, ancak kullanıcıyla etkileşime girerek şifre, tam isim, oda numarası gibi bilgileri adım adım soran interaktif bir Perl script'idir. Ev dizinini ve temel ayar dosyalarını otomatik olarak oluşturur.

3. useradd ile Temel Kullanıcı Oluşturma ve Silme Pratikleri

- **sudo useradd username:** Sistemde tanımlı varsayılan ayarlara göre bir kullanıcı oluşturur (Çoğu dağıtımda bu komut yalın çalıştırıldığında kullanıcıya bir ev dizini oluşturmaz).
- **sudo useradd -m username:** Kullanıcıyı oluştururken, kullanıcı adıyla eşleşen ev dizinini (/home/username) otomatik olarak inşa eder.
- **sudo useradd -c "Mert Bonceoglu" username:** Kullanıcı kaydına açıklama (GECOS / Comment) alanı ekler. Genellikle personelin tam adını veya departmanını belirtmek için kullanılır.
- **sudo useradd -D:** Sistemde useradd komutu hiçbir parametre verilmeden çalıştırıldığında kullanılacak olan varsayılan (default) ayarları terminal ekranında listeler.
- **sudo useradd -D -s /bin/bash:** useradd -D komutunun yanına -s gibi parametreler eklendiğinde, gelecekte oluşturulacak tüm yeni kullanıcılar için varsayılan giriş kabuğunu kalıcı olarak değiştirir.
- **sudo userdel -r username:** Belirtilen kullanıcı hesabını sistemden siler. Buradaki -r (recursive) parametresi güvenlik ve temizlik açısından kritiktir; kullanıcının sadece hesabını silmekle kalmaz, /home/username altındaki tüm kişisel dosyalarını ve mail kuyruğunu da sistemden tamamen temizler.

4. Ev Dizini ve Kabuk (Shell) Özelleştirmeleri

- **sudo useradd -M username:** Kullanıcı için kesinlikle bir ev dizini oluşturulmasını engeller. Genellikle sadece belirli bir servisi çalıştırmak için açılan ve interaktif olarak sisteme giriş yapmayacak olan servis hesapları için bu parametre güvenlik açısından zorunludur.
- **sudo useradd -d /srv/appuser appuser:** Kullanıcının ev dizinini varsayılan /home dizini altında değil, belirtilen özel bir yolda (/srv/appuser) oluşturur.
- **sudo useradd -s /bin/zsh username:** Kullanıcının sisteme giriş yaptığında kullanacağı varsayılan login kabuğunu (shell) değiştirir (örneğin Zsh olarak ayarlar).
- **sudo useradd -s /usr/sbin/nologin serviceuser:** Kullanıcının interaktif olarak sisteme giriş yapmasını tamamen engeller. Bu hesapla SSH veya yerel terminal üzerinden oturum

açılmaya çalışıldığında sistem bağlantıyı anında reddeder. Servis hesaplarının siber suçlular tarafından ele geçirilip komut satırı olarak kullanılmasını önleyen kritik bir sıkılaştırma adımıdır.

BÖLÜM 8: LINUX/UNIX KULLANICI YÖNETİMİ VE GÜVENLİĞİ (BÖLÜM 2)

Linux işletim sistemlerinde güvenlik ve erişim denetimi, kullanıcıların hiyerarşik gruplara dahil edilmesi ve sıkı hesap yaşlanma (aging) politikalarının uygulanması ile güçlendirilir.

1. Gruplar, Yetki Atamaları ve Hesap Yönetimi

Linux mimarisinde her dosya ve süreç belirli bir kullanıcı ve gruba aittir; erişim yetkileri bu sahiplikler üzerinden dağıtılır.

- **Birincil Grup (Primary Group):** Kullanıcının doğrudan bağlı olduğu ana gruptur. Kullanıcı sisteme tanımlandığı anda bu gruba atanır ve oluşturduğu tüm yeni dosyaların grup sahipliği otomatik olarak bu birincil gruba verilir. Komut: `sudo useradd -g developers username`.
- **İkincil/Ek Gruplar (Supplementary Groups):** Kullanıcıya ek yetkiler tanımlamak için kullanılan ikincil üyeliklerdir. Komut: `sudo useradd -G sudo,docker username`.
- **Mevcut Kullanıcıyı Gruba Ekleme (usermod):** Sistemde halihazırda var olan bir kullanıcının yetki sınırlarını değiştirmek için `usermod` komutu kullanılır. `sudo usermod -aG sudo newuser` komutu mevcut bir kullanıcıyı yönetici yetkilerine sahip `sudo` grubuna ekler. Buradaki `-a` (append/ekle) parametresi hayati önem taşır; eğer `-a` parametresi unutulup sadece `-G` kullanılırsa, kullanıcı daha önce üye olduğu tüm diğer ikincil gruplardan çıkarılır ve sadece yeni belirtilen gruba atanır. Bu durum kurumsal yetki matrislerinin bozulmasına yol açar.
- **Grup Bilgilerini Doğrulama:** `id username` kullanıcının UID (User ID), GID (Group ID) değerlerini ve üye olduğu tüm birincil/ikincil grupları listeler. `groups username` ise kullanıcının sadece üye olduğu grupların isimlerini terminalde gösterir.

2. Hesap Ömrü ve Kimlik Sıkılaştırma Parametreleri

Geçici personel veya stajyerler için açılan hesapların unutulması siber saldırganlar için büyük bir arka kapı oluşturduğundan proaktif önlemler alınmalıdır.

- **`sudo useradd -u 1050 username`:** Kullanıcıya sistem tarafından otomatik bir ID atanması yerine, spesifik bir UID (User ID) tanımlar.
- **`sudo useradd -e 2026-12-31 username`:** Hesaba bir son kullanma tarihi (expiration date) koyar; belirtilen tarihten sonra hesap sistem tarafından otomatik olarak kilitlenir.
- **`sudo useradd -f 30 username`:** Şifrenin süresi dolduktan sonra, hesap tamamen devre dışı bırakılmadan önce kullanıcıya tanınacak inaktif gün sayısını belirler.
- **`sudo useradd -k /etc/skel username`:** Yeni oluşturulan kullanıcının ev dizinine otomatik olarak kopyalanacak olan temel yapılandırma dosyalarının (`.bashrc`, `.profile` vb.) alınacağı iskelet (skeleton) dizinini belirtir.

- **sudo chage -l username:** Bir kullanıcının hesap yaşlanma, şifre değiştirme sıklığı ve hesabın son kullanma tarihi politikalarını derinlemesine incelemek için adli bilişim ve denetim süreçlerinde kullanılan kritik inceleme komutudur.

3. Şifre Yönetimi ve Hesap Aktivasyonu

- **sudo passwd username:** Yeni oluşturulan ve henüz şifresi olmadığı için kilitli olan hesabın şifresini belirler veya mevcut şifreyi sıfırlar.
- **sudo passwd -l username:** Belirtilen kullanıcının şifresini kilitler (lock). Kullanıcı doğru şifreyi girse bile sisteme erişemez; şüpheli aktivasyonlarda hesabı acilen dondurmak için kullanılır.
- **sudo passwd -u username:** Kilitlenmiş olan şifreli oturum açma özelliğini tekrar aktif hale verir (unlock).
- **sudo su - username:** Yöneticinin, yeni oluşturulan kullanıcının ortam değişkenlerini, kabuk ayarlarını ve ev dizini yetkilerini test etmek için o kullanıcının kimliğine bürünmesini sağlar.

4. Kabuk Türleri: SH ve BASH Arasındaki Temel Farklar

- **SH (Bourne Shell):** Unix sistemlerin en eski ve en temel kabuğudur. /bin/sh yolunda konumlanır. Komut geçmişi tutma, sekme tuşuyla otomatik tamamlama, gelişmiş takma adlar (alias) gibi gelişmiş özellikleri barındırmaz. Genellikle çok eski sistemlerle uyumluluk (backward compatibility) ve en yalın script'leri çalıştırmak için kullanılır.
- **BASH (Bourne Again Shell):** sh kabuğunun üzerine geliştirilmiş, günümüz modern Linux dağıtımlarının neredeyse tamamında varsayılan olarak gelen gelişmiş kabuk türüdür. /bin/bash yolunda bulunur. Ok tuşlarıyla geçmiş komutlara erişim, otomatik tamamlama, gelişmiş programlama fonksiyonları ve kullanıcı dostu bir terminal deneyimi sunar.

BÖLÜM 9: AĞ GÜVENLİĞİ LABORATUVARI VE TERMİNAL ÇIKTI ANALİZLERİ

Sınavda ağ taramasının veya zafiyet raporunun çıktısını okuyabilmek ve analitik çıkarımlar yapabilmek kritik önem taşır. Aşağıda gerçek dünya laboratuvar senaryolarının adli incelemeleri yer almaktadır.

Hedef Sistem Üzerinde nmap -sS -sV -O Taraması ve Analizi

Aşağıdaki terminal çıktısı, yerel ağdaki bir sunucuya karşı yürütülen Yarı Açık SYN Tarama (-sS), Servis Versiyon Tespiti (-sV) ve İşletim Sistemi Doğrulama (-O) kombinasyonunun sonucudur:

```
$ sudo nmap -sS -sV -O 192.168.1.150
```

```
PORT      STATE SERVICE VERSION
```

```
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
```

```
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
```

```
443/tcp   open  ssl/http Apache httpd 2.4.41 ((Ubuntu))
```

3306/tcp open mysql MySQL 8.0.25-0ubuntu0.20.04.1

MAC Address: 00:0C:29:3E:B2:A1 (VMware, Inc.)

OS details: Linux 5.4 - 5.11

Çıktıdan Çıkarılması Gereken Kritik Bulgular

- **Canlılık Durumu:** Hedef cihaz ağda aktiftir.
- **Port 22 (SSH):** Uzaktan yönetim servisi açıktır ve OpenSSH 8.2p1 sürümü çalışmaktadır. Bilinen açıkları zafiyet veritabanlarında (CVE) aranabilir.
- **Port 80 & 443 (HTTP/HTTPS):** Cihaz bir web sunucusudur ve Apache 2.4.41 kullanmaktadır.
- **Port 3306 (MySQL):** Sunucuda veritabanı aktiftir. Dış ağa doğrudan açık olması büyük bir güvenlik riskidir.
- **Donanım Altyapısı:** MAC Address satırındaki (VMware, Inc.) bilgisi cihazın bir sanal makine olduğunu ifşa eder.
- **İşletim Sistemi:** Sistem kesin olarak Linux (Kernel 5.4 - 5.11) tabanlıdır.